

Module 19

Active Directory Enumeration

Dari object inventory ke relationship graph: DNS, LDAP, SMB/RPC, users, groups, computers, SPNs, GPO, ACL, trusts, BloodHound CE, dan attack-path reasoning pada lab AD yang terotorisasi.

Scope modul Seluruh langkah ofensif hanya untuk GOAD/MINILAB, domain milik sendiri, HTB/THM, atau engagement dengan izin tertulis. Enumeration tetap menghasilkan network traffic dan telemetry.

Learning path module ini

Input	Proses	Output
Module 18: AD mental model	Enumerate object + relationship secara bertahap	Inventory yang bisa diaudit
Authorized credentials	DNS → LDAP → SMB/RPC → graph	Evidence + attack hypotheses
Raw observations	Normalize dan korelasi	Handoff ke Module 20 attack paths

Exit criteria

- Bisa membedakan object enumeration, relationship enumeration, dan host/session enumeration.
- Bisa mengumpulkan users, groups, computers, SPNs, trusts, GPO links, shares, dan sample ACL tanpa mengubah domain.
- Bisa menjelaskan kenapa sebuah edge di BloodHound adalah relationship evidence, bukan otomatis exploit path.
- Bisa menyimpan hasil enumeration sebagai evidence terstruktur dan menghindari password di command history.

1. Enumeration Mindset: Object → Relationship → Path

Enumeration AD bukan satu command “enum all”. Kerja yang rapi dimulai dari pertanyaan: object apa yang ada, relationship apa yang menghubungkan object tersebut, dan relationship mana yang relevan dengan objective engagement.

Layer	Pertanyaan	Contoh evidence
Object	Apa saja yang ada?	users, groups, computers, OUs, GPOs
Attribute	Apa sifat object itu?	enabled, OS, SPN, UPN, description
Relationship	Siapa terhubung ke siapa?	memberOf, ACL, GPO link, trust
Host context	Apa yang terjadi di endpoint?	share, session, local group — jika RoE mengizinkan
Path	Gabungan relationship mana yang relevan?	identity → permission → target

Red Team Perspective Tujuan enumeration bukan menghasilkan output sebanyak mungkin. Tujuannya mengurangi uncertainty sambil menjaga scope, noise, dan evidence quality.

2. Lab Boundary & Tooling di Omarchy

GOAD adalah intentionally vulnerable AD pentest lab. Dokumentasi resminya memperingatkan agar environment tidak diekspos ke internet. Untuk resource lebih ringan, MINILAB terdiri dari 1 forest, 1 domain, 1 DC, dan 1 workstation.

Komponen	Fungsi	Catatan
dig / bind	DNS + SRV discovery	read-only query
ldapsearch	LDAP object query	gunakan -W / Kerberos; hindari password di argv
smbclient	SMB share listing / browsing	akses sesuai credential
rpcclient	MS-RPC/SAMR/LSA query	gunakan hanya pada lab/RoE yang mengizinkan
PowerShell ActiveDirectory	native AD object query	ideal dari Windows lab/jump host
SharpHound + BloodHound CE	relationship collection + graph analysis	mulai dari scope kecil / DCOonly

omarchy pkg add bind openldap samba jq python

```
# verifikasi tool
dig -v
ldapsearch -VV
smbclient --version
rpcclient --version
```

Credential hygiene Jangan taruh password setelah -p, --password, atau di script yang masuk Git. Pilih prompt interaktif, Kerberos ticket, auth file mode 600, atau secret store yang sesuai engagement.

3. Phase 1 — Domain & DC Discovery via DNS

AD sangat bergantung pada DNS. SRV records mengiklankan lokasi service seperti LDAP/Kerberos dan membantu client menemukan Domain Controller. Enumeration yang baik biasanya dimulai dari naming + service discovery, bukan langsung crawling seluruh subnet.

```
dig +short SRV _ldap._tcp.dc._msdcs.<domain>
dig +short SRV _kerberos._tcp.<domain>
dig +short A <dc-fqdn>
dig +short -x <dc-ip>
```

Interpretasi Catat FQDN DC, priority/weight SRV, resolver yang dipakai, serta apakah forward/reverse naming konsisten. DNS mismatch sering menjelaskan error Kerberos/LDAP.

Lab 01 — DNS & DC Baseline

Objective Buat baseline domain, DC, LDAP/Kerberos SRV, dan resolusi nama tanpa melakukan port sweep.

```
./labs/workspace-init.sh module19-ad-enum
./labs/dns-ad-enum.sh <domain> module19-ad-enum/01-dns/dns.txt
```

2. Simpan domain name, DC FQDN, IP, dan SRV records sebagai inventory awal.

Evidence yang harus disimpan 01-dns/dns.txt + catatan domain/DC yang sudah divalidasi.

4. Phase 2 — LDAP Fundamentals untuk Enumeration

LDAP memberi akses terstruktur ke directory objects. Dua hal paling penting adalah search base (mis. DC=lab,DC=local) dan filter. Jangan mulai dengan “semua attributes untuk semua objects” jika kebutuhan engagement bisa dijawab dengan query yang lebih sempit.

Goal	LDAP filter contoh	Attributes minimal
Users	(&(objectCategory=person)(objectClass=user))	sAMAccountName,userPrincipalName,memberOf
Groups	(objectClass=group)	cn,member,groupType
Computers	(objectClass=computer)	dNSHostName,operatingSystem
SPN-bearing users	(&(objectClass=user)(servicePrincipalName=*))	sAMAccountName,servicePrincipalName
GPO objects	(objectClass=groupPolicyContainer)	displayName,name,gPCFileSysPath

contoh authenticated query; -W meminta password via prompt

```
ldapsearch -x -H ldap://<dc-fqdn> \
-D '<user-dn>' -W \
-b '<base-dn>' \
'(&(objectCategory=person)(objectClass=user))' \
sAMAccountName userPrincipalName memberOf
```

Production mindset Batasi attributes dan search base. Output LDAP dapat memuat description, phone, mail, path, dan data organisasi lain yang tetap dianggap sensitive evidence.

Lab 02 — LDAP RootDSE & Naming Context

Objective Temukan naming context terlebih dulu sebelum query object.

```
ldapsearch -x -H ldap://<dc-fqdn> -s base -b "" \
defaultNamingContext rootDomainNamingContext namingContexts
```

2. Catat defaultNamingContext dan jangan menebaknya dari domain string kalau server sudah memberi jawaban authoritative.

Evidence yang harus disimpan 02-ldap/rootdse.txt

Lab 03 — Users, Groups, Computers

Objective Ambil inventory object inti dengan field minimum yang relevan.

```
./labs/ldap-enum.sh users <dc-fqdn> <base-dn> <user-dn>
./labs/ldap-enum.sh groups <dc-fqdn> <base-dn> <user-dn>
./labs/ldap-enum.sh computers <dc-fqdn> <base-dn> <user-dn>
```

2. Bandingkan jumlah object dan tandai object service/admin hanya sebagai candidate untuk analisis berikutnya.

Evidence yang harus disimpan 02-ldap/users.ldif, groups.ldif, computers.ldif

5. Phase 3 — Native PowerShell Enumeration

Jika lo punya Windows test host dengan RSAT/ActiveDirectory module, cmdlet Get-AD* memberi output object yang mudah difilter. Microsoft mendokumentasikan bahwa Get-ADUser/Get-ADGroup mendukung Filter, LDAPFilter, SearchBase, dan Properties untuk mempersempit query.

```
Import-Module ActiveDirectory
Get-ADDomain
Get-ADForest
```

```
Get-ADUser -Filter * -Properties Enabled,MemberOf,ServicePrincipalName |
Select-Object SamAccountName,Enabled,MemberOf,ServicePrincipalName
```

```
Get-ADGroup -Filter * | Select-Object Name,GroupScope,GroupCategory
Get-ADComputer -Filter * -Properties DNSHostName,OperatingSystem,LastLogonDate |
Select-Object Name,DNSHostName,OperatingSystem,LastLogonDate
```

Lab 04 — Structured AD Inventory

Objective Ekspor object inventory ke CSV dari Windows lab tanpa melakukan perubahan directory.

```
.\labs\ad-object-inventory.ps1 -OutputDir .\module19-ad-enum\03-powershell
```

2. Review CSV dan tandai data yang sensitif sebelum dipindahkan keluar lab.

Evidence yang harus disimpan users.csv, groups.csv, computers.csv, domain.json, forest.json

6. Group Membership & Privilege Context

Group membership adalah salah satu relationship paling penting di AD. Jangan hanya mencari “Domain Admins”; nested groups, delegated operator groups, dan application groups juga dapat membentuk privilege chain.

```
Get-ADGroupMember -Identity 'Domain Admins' -Recursive |
Select-Object objectClass,Name,SamAccountName
```

```
Get-ADPrincipalGroupMembership -Identity <user> |
Select-Object Name,GroupScope
```

Pertanyaan	Kenapa penting
Apakah membership direct atau nested?	nested group dapat menyembunyikan privilege
Scope group apa?	Domain Local/Global/Universal memengaruhi jangkauan
Apakah group terkait delegated admin?	privilege tidak selalu bernama “admin”
Apakah relationship current atau legacy?	stale groups tetap dapat berbahaya

Lab 05 — Nested Group Map

Objective Bangun peta group membership untuk 2–3 identity lab.

```
.\labs\group-map.ps1 -Identity <user> -OutputPath .\module19-ad-enum\04-relations\group-map.csv
```

2. Tulis satu hipotesis: membership mana yang layak diperiksa lebih lanjut dan kenapa.

Evidence yang harus disimpan group-map.csv + satu hypothesis note.

7. SPN & Service Account Inventory

Service Principal Name (SPN) mengikat service instance ke security principal. Pada tahap enumeration, objective-nya adalah mengetahui service identities dan dependensi — bukan langsung melakukan ticket extraction.

```
Get-ADUser -LDAPFilter '(servicePrincipalName=*)' \
-Properties ServicePrincipalName,MemberOf,PasswordLastSet |
Select-Object SamAccountName,ServicePrincipalName,MemberOf,PasswordLastSet
```

Boundary Module 19 berhenti pada SPN/service-account inventory. Kerberos attack techniques dibahas terpisah di Module 20 dan tetap hanya untuk authorized lab.

Lab 06 — SPN Inventory

Objective Ekspor service-account/SPN relationship dan normalisasi satu SPN per row.

```
.\labs\spn-inventory.ps1 -OutputPath .\module19-ad-enum\04-relations\spns.csv
```

2. Kelompokkan service type (HTTP/MSSQL/CIFS/dll.) dan owner identity bila diketahui.

Evidence yang harus disimpan spns.csv

8. SMB Shares & RPC: Enumerate What the Credential Can See

SMB/RPC memberi perspective berbeda dari LDAP: resource exposure, share names, dan beberapa account/domain query. Samba mendokumentasikan smbclient sebagai SMB/CIFS client dan rpcclient sebagai utility untuk MS-RPC calls.

```
# share listing; password diminta via prompt
smbclient -L //<server> -U '<DOMAIN>/<user>'
```

```
# interactive RPC client; jalankan hanya di authorized lab
rpcclient -U '<DOMAIN>/<user>' <server>
# di prompt rpcclient, gunakan help lalu query yang memang diizinkan
```

Avoid credential leaks Jangan tulis DOMAIN/user%password di shell history. Jika automation perlu auth file, simpan mode 600 dan masukkan path itu ke .gitignore.

Lab 07 — SMB Share Inventory

Objective Daftar share yang dapat dilihat test identity tanpa download massal.

```
./labs/smb-share-enum.sh <server> <DOMAIN>/<user> module19-ad-enum/05-smb/shares.txt
```

2. Klasifikasikan share: administrative, SYSVOL/NETLOGON, application, user data, unknown.

Evidence yang harus disimpan 05-smb/shares.txt

Lab 08 — RPC Read-only Queries

Objective Pelajari RPC commands dari help dan jalankan query minimum yang diizinkan RoE.

1. Gunakan rpcclient interactive mode agar password tidak muncul di argv/history.
2. Catat command yang dipakai, timestamp, dan object count; jangan melakukan mutation RPC.

Evidence yang harus disimpan 05-smb/rpc-notes.md

9. GPO & SYSVOL Enumeration

Group Policy adalah hubungan antara GPO object, link location (site/domain/OU), dan settings yang akhirnya diterapkan ke computer/user. Enumeration yang benar memisahkan “GPO exists” dari “GPO applies to target”.

```
Get-GPO -All | Select-Object DisplayName,Id,GpoStatus
Get-ADOrganizationalUnit -Filter * -Properties gPLink |
  Select-Object DistinguishedName,gPLink
```

Lab 09 — GPO Link Inventory

Objective Ekspor GPO + OU link dan korelasikan satu workstation/user dengan OU path-nya.

```
.\labs\gpo-link-inventory.ps1 -OutputDir .\module19-ad-enum\06-gpo
```

2. Tulis: GPO apa yang link ke OU target? jangan simpulkan setting efektif sebelum memeriksa inheritance/filtering.

Evidence yang harus disimpan gpos.csv + ou-gplinks.csv

10. ACL Enumeration: Dari Permission ke Edge

AD object permissions disimpan pada security descriptor/DACL. Sebuah ACE dapat memberi kemampuan membaca, menulis attribute tertentu, mengubah membership, reset password, mengambil ownership, atau kontrol yang lebih luas.

Enumeration ACL harus fokus pada object penting dan principal yang relevan, bukan dump seluruh directory tanpa tujuan.

```
# contoh membaca ACL satu object dari AD: provider
$dn = 'CN=<user>,OU=<ou>,DC=<domain>,DC=<tld>'
(Get-Acl "AD:$dn").Access |
  Select-Object IdentityReference,ActiveDirectoryRights,AccessControlType,ObjectType,InheritedObjectType,IsInherited
```

Reasoning rule ACE → capability candidate. Untuk menjadi attack-path edge yang meaningful, lo masih harus memahami target object, inheritance, object type, current identity, dan apakah capability dapat digunakan dalam kondisi engagement.

Lab 10 — Sample ACL Review

Objective Ambil ACL hanya untuk 3–5 object lab yang sudah dipilih.

```
.\labs\acl-sample.ps1 -Identity '<DN>' -OutputPath .\module19-ad-enum\07-acl\acl.csv
```

2. Pilih satu ACE dan jelaskan principal → right → target → inherited/direct.

Evidence yang harus disimpan 07-acl/acl.csv + relationship note

11. Trust Enumeration

Trust menghubungkan authentication boundary antar-domain/forest. Pada tahap enumeration, catat direction, transitivity, source/target, dan forest/domain boundary — belum melakukan cross-trust exploitation.

```
Get-ADTrust -Filter * |
Select-Object Name,Source,Target,Direction,ForestTransitive,IntraForest
```

Lab 11 — Trust Map

Objective Gambar trust map sederhana dari data domain/forest lab.

```
.\labs\trust-inventory.ps1 -OutputPath .\module19-ad-enum\08-trusts\trusts.csv
```

2. Bedakan parent/child intra-forest relationship dari external/forest trust jika lab memilikinya.

Evidence yang harus disimpan trusts.csv + trust-map.md

12. BloodHound CE: Relationship Graph, Bukan “Magic Path Finder”

BloodHound memodelkan users, groups, computers, domains, GPO, ACL, sessions, dan relationship lain sebagai graph. SharpHound adalah collector AD untuk BloodHound CE. Repo resmi SharpHound menyebut collector harus dijalankan dalam konteks domain user dan mendukung collection methods seperti Group, ACL, ObjectProps, Trusts, Session, serta DOnly.

Start small Untuk belajar, mulai dari collection scope kecil/read-only seperti DOnly pada domain lab. Tambahkan host/session collection hanya jika tujuan lab memerlukannya dan RoE mengizinkan karena metode tersebut dapat menyentuh banyak endpoint.

```
# ambil versi collector dari BloodHound CE UI yang kompatibel
SharpHound.exe -help
```

```
# contoh training: collector domain-controller-centric
SharpHound.exe -c DOnly -d <lab-domain>
```

```
# import ZIP output ke BloodHound CE, lalu analisis graph
```

Node/edge	Pertanyaan analyst
MemberOf	membership direct/nested?
AdminTo / local group	data source apa dan masih current?
GenericWrite/GenericAll	target object apa? inherited atau direct?
GPO link/rights	GPO berlaku ke OU/host mana?
Session	snapshot kapan? edge cepat stale
Trust	boundary + direction + transitivity?

Lab 12 — BloodHound DOnly Baseline

Objective Collect + import relationship graph minimum pada authorized lab.

1. Pastikan versi SharpHound diambil dari BloodHound CE Settings → Download Collectors.

```
SharpHound.exe -c DOnly -d <lab-domain>
```

3. Hash ZIP evidence sebelum import, lalu simpan query notes — jangan upload data lab ke layanan publik.

Evidence yang harus disimpan SharpHound ZIP hash + screenshot/query notes + collection timestamp

13. Attack-Path Reasoning & Data Quality

Graph analysis harus mempertimbangkan freshness dan provenance. “Path exists” bukan berarti “path exploitable sekarang”. Session bisa stale, host offline, ACL inherited dapat berubah, dan privilege bisa dibatasi oleh controls lain.

Check	Pertanyaan
Provenance	edge berasal dari LDAP, host API, session, atau manual evidence?
Freshness	kapan data dikumpulkan?
Reachability	host/service target bisa dicapai dari posisi tester?
Precondition	credential/privilege/tooling apa yang dibutuhkan?
Boundary	apakah langkah berikut masih in-scope?
Impact	objective apa yang sebenarnya tercapai jika edge valid?

Lab 13 — Path Triage

Objective Pilih satu path BloodHound dan buat validation plan tanpa mengeksploitasinya.

1. Catat node awal, setiap edge, target node, data source, freshness, dan precondition.
2. Tandai edge yang membutuhkan active validation; jangan otomatis menjalankannya.

Evidence yang harus disimpan 09-graph/path-triage.md

14. Enumeration Noise, Telemetry & Blue Team View

Enumeration bukan invisible. LDAP query volume, SMB authentication, RPC calls, directory service access, endpoint connection, dan SharpHound activity dapat menghasilkan telemetry. Red Teamer yang matang tahu kapan informasi yang didapat tidak sebanding dengan noise.

Activity	Defender may observe
High-volume LDAP	unusual directory query patterns / DC load
SMB/RPC sweep	many authentications or IPC\$/named pipe access
Session/local group collection	connections across many workstations
SharpHound execution	process/script telemetry + network pattern
Repeated failed auth	authentication failures / lockout risk

Operational rule Jangan mengubah enumeration menjadi password spraying atau unrestricted endpoint crawling. Kalau perlu memperluas collection method, catat alasan dan RoE approval.

15. Evidence Workflow & Normalization

Enumeration yang berguna harus bisa direview tester lain. Pisahkan raw evidence dari normalized inventory dan analytical notes.

```
module19-ad-enum/
├── 00-scope/
├── 01-dns/
├── 02-ldap/
├── 03-powershell/
├── 04-relations/
├── 05-smb/
├── 06-gpo/
├── 07-acl/
├── 08-trusts/
├── 09-graph/
├── 10-evidence/
└── 11-summary/
```

Lab 14 — Evidence Manifest

Objective Hash evidence dan buat ringkasan object/relationship count.

```
./labs/evidence-manifest.sh module19-ad-enum
```

```
python labs/enumeration-summary.py module19-ad-enum --output module19-ad-enum/11-summary/summary.md
```

Evidence yang harus disimpan manifest.sha256 + summary.md

16. Guided Capstone — Enumerate an Unknown AD Lab

Scenario Lo diberi 1 domain credential low-privilege dan alamat DNS/DC pada GOAD/MINILAB/authorized range. Tidak ada attack path yang diberikan.

Objective capstone: hasilkan inventory dan 3 attack hypotheses tanpa menjalankan privilege escalation/credential attacks.

- 1) Validate scope + time sync + DNS; 2) identify domain/DC; 3) RootDSE/base DN; 4) users/groups/computers; 5) group relationships; 6) SPNs; 7) SMB shares; 8) GPO links; 9) sample ACLs; 10) trusts; 11) BloodHound DCOOnly; 12) triage 3 relationships.
- Deliverable: summary.md, evidence manifest, object inventory, relationship notes, graph/path screenshot, dan 3 hypotheses dengan precondition + next validation step.
- Rule: jangan melakukan Kerberoasting, password spraying, ACL abuse, remote execution, atau privilege escalation di capstone Module 19.

17. Common Mistakes & Troubleshooting

Symptom	Kemungkinan penyebab / fix
Kerberos error / hostname mismatch	cek DNS, FQDN, time sync, realm/domain
LDAP bind gagal	cek DN/UPN format, TLS requirement, credential, DC target
Empty LDAP result	search base/filter salah atau attribute visibility berbeda
smbclient auth gagal	gunakan DOMAIN/user; cek DNS/SMB reachability; jangan asumsi guest
BloodHound graph minim	collection method/scope terlalu sempit atau import belum lengkap
Path terlihat aneh	cek data freshness, edge provenance, object duplicate/stale

18. Cheat Sheet

Goal	Command / idea
LDAP DC SRV	dig +short SRV _ldap._tcp.dc._msdcs.<domain>
RootDSE	ldapsearch -x -H ldap://<dc> -s base -b "defaultNamingContext"
PowerShell users	Get-ADUser -Filter * -Properties Enabled,MemberOf,ServicePrincipalName
Groups	Get-ADGroup -Filter *; Get-ADGroupMember <group> -Recursive
Computers	Get-ADComputer -Filter * -Properties DNSHostName,OperatingSystem
SPNs	Get-ADUser -LDAPFilter '(servicePrincipalName=*)' -Properties ServicePrincipalName
Shares	smbclient -L //<server> -U '<DOMAIN>/'<user>'
Trusts	Get-ADTrust -Filter *
BloodHound baseline	SharpHound.exe -c DCOOnly -d <lab-domain>
Evidence	hash raw output; normalize separately; timestamp collection

19. Knowledge Check

1. Apa perbedaan object enumeration, relationship enumeration, dan attack-path analysis?
2. Kenapa DNS/SRV discovery lebih berguna daripada langsung subnet sweep untuk memulai AD enumeration?
3. Apa fungsi search base dan LDAP filter?
4. Kenapa password tidak boleh diletakkan di argument command line?
5. Apa perbedaan direct dan nested group membership?
6. Apa yang direpresentasikan SPN?
7. Kenapa share visibility tidak berarti write access?
8. Apa beda GPO exists dengan GPO applies?
9. Apa yang perlu dicatat dari sebuah ACE agar meaningful?
10. Apa atribut trust yang penting untuk dipetakan?
11. Kenapa session edge cepat menjadi stale?
12. Kenapa path BloodHound bukan bukti exploitability?
13. Kapan DCOOnly lebih tepat daripada broad collection?
14. Apa risiko operational dari endpoint/session collection?
15. Mengapa raw evidence harus dipisahkan dari normalized inventory?

20. Referensi Utama

- Microsoft Learn — ActiveDirectory PowerShell module: Get-ADUser, Get-ADGroup, Get-ADComputer, Get-ADTrust.
- Samba Documentation — smbclient(1) dan rpcclient(1).
- SpecterOps — BloodHound Community Edition & SharpHound documentation/repository.
- Orange Cyberdefense — GOAD / MINILAB documentation and isolation warning.
- Microsoft Learn — Active Directory Domain Services, Group Policy, security descriptors, trusts, Kerberos/DNS fundamentals.

Next Module 20 akan membahas Kerberos & AD Attack Paths: ticket model, SPN/service-account paths, ACL/delegation concepts, AD CS fundamentals, trust paths, dan controlled validation di authorized lab.